DNS Behavior & Covert Channels

From Resolution Lifecycle to
Detecting Hidden Exfiltration Channels

By Haydn Kuti

DNS Threat Hunting & Analysis

Bridging the Visibility Gap

Core Objective: Mastering the invisible protocol for threat hunting.

- **The DNS Blind Spot**
  - Often ignored by basic firewall; Port 53 is usually wide open.
  - High Volume of traffic makes manual inspection difficult without strategy
- **Our Goals**
  - Defining the baseline of normal DNS traffic
  - Identifying the fingerprints of reconnaissance and DGA (Domain Generation Algorithm).
  - Deconstructing DNS tunneling and data exfiltration techniques.

The Resolution Lifecycle

Following the Packet: From Client to the Root

Recursive

- **The Request**: The client (your laptop) asks the DNS resolver (like your ISP or 8.8.8.8) for IP address.
- **The Responsibility**: The resolver takes full responsibility. If it doesn't know the answer, it goes out and talks to other servers on your behalf.
- **The Result**: The resolver either returns the correct address or an error message (NXDOMAIN). The client just waits.
- **Security Angle**: This is where **DNS Caching** happens, which is a prime target for **DNS Cache Poisoning**.

Iterative

- **The Request**: The DNS resolver asks a Root or TLD (Top-Level Domain) server for the IP.
- **The Response**: The server doesn't hunt for the answer. Instead, it refers the resolver to the next authoritative server in the chain ("I don't know example.com, but here's the IP for the .com Name Server").
- **The Loop**: The resolver repeats this process (iterates) until it reaches the specific Authoritative Name Server for that domain.
- **Security Angle**: Attackers often monitor iterative traffic to map out infrastructure or identify which upstream servers a company trusts.

The Hierarchy

- (.) > `TLD Servers` (.com) > `Authoritative Servers` (example.com).
- Understanding where the handoff happens to spot redirection hijacks.

Deconstructing Queries and Responses

Anatomy of a DNS Packet

```
▾ Domain Name System (query)
    Transaction ID: 0xee73
  ▸ Flags: 0x0120 Standard query
    Questions: 1
    Answer RRs: 0
    Authority RRs: 0
    Additional RRs: 1
  ▸ Queries
  ▸ Additional records
    [Response In: 64]
```

The Header Section

- `Transaction ID`: Matching requests to responses.
- `Flags`: Is this a query or response? Is recursion desired?

The Question Section

- `Query Name`: The domain being sought.
- `Query Type`: A, AAAA, TXT, MX, etc.

The Resource Records

- `Answers`, `Authority`, and `Additional` sections providing the resolution data.

Standard Response Codes

Interpreting Server Feedback

Status Indicators

- **NOERROR (0)**: Success; record found (or exists without data).
- **FORMERR (1)**: Format error; query interpretation failed.
- **SERVFAIL (2)**: General failure or DNSSEC validation break.
- **NXDOMAIN (3)**: Non-existent domain; name not in registry.
- **REFUSED (5)**: Request blocked by server policy or ACL

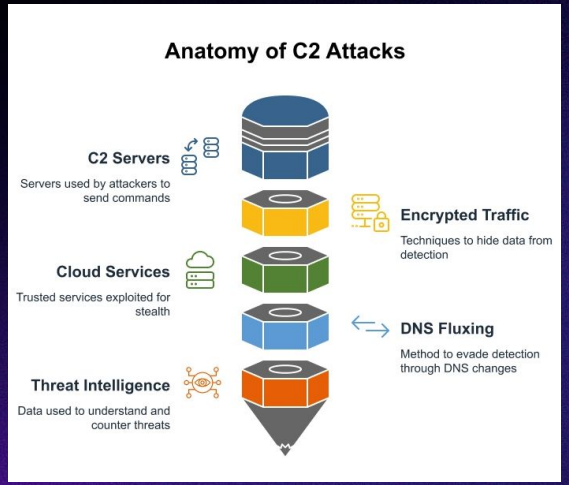
Security Implications

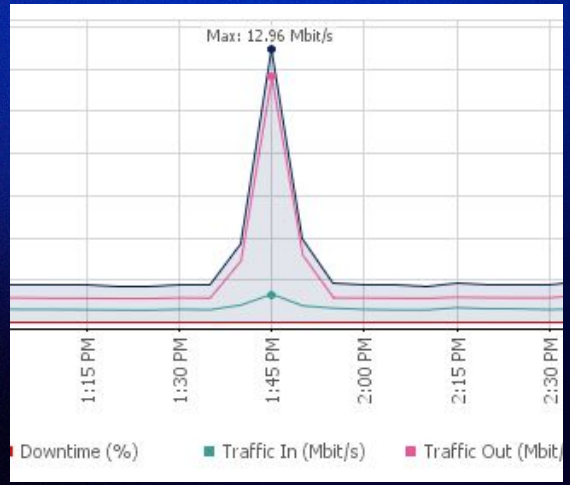
- **Security Tripwires**: SERVFAIL often signals a hijacked or invalid DNSSEC signature.
- **Reconnaissance**: High NXDOMAIN volume suggests subdomain brute-forcing.
- **Policy Hits**: REFUSED indicates unauthorized queries or Split-Horizon conflicts.
- **Negative Caching**: Errors are cached; a single typo can break a site for hours.
- **Information Leakage**: Specific error codes can help attackers fingerprint DNS software.

om xpwYswUzvw.example.com UITjWyxVpP.example.com mrCubQMFJU.example.com xrESjpbMBG.example.com YJOklGLKfJ.example.com IAiiCXawjk.example.com ujJvQXFXtu.e
ePqqQaxM.example.com vOmdtRgFta.example.com ZldxrmdEzV.example.com sdGYCEjcOF.example.com MDRNwTKGMD.example.com hSwMmYiTMt.example.com nNHJUfZfhA.exampl
anm.example.com QeNXhZHoQh.example.com SaBMyVMkQn.example.com aywrPYCtom.example.com rmVGhnEaQh.example.com YOdVMHjLRE.example.com lcmQprAqJs.example.com
xample.com OWnfHpvfRw.example.com JQNQOtYceu.example.com dKPFxcCAeu.example.com AouMLUFaZa.example.com JltMmANtwr.example.com BhLcfbixJM.example.com avlt
e.com pqqOokJBSF.example.com kJshoCfjrn.example.com FUSUeCFHOs.example.com aXKKKLCmZY.example.com wmmDpNEJrI.example.com kbdSiTVFBq.example.com hbgQbUcaZ
xTGzIagxZa.example.com sugsgLkOVT.example.com DpKzMrXGaq.example.com FclJevINlK.example.com ZpMXPYXAna.example.com pCmhnMguSo.example.com uYVIMOvUNd.exa
WmrSAE.example.com QDzuPfrvbt.example.com FvSkFIRcDS.example.com jeROskTxYD.example.com oKEwJwIkzi.example.com ktZQLkCBGE.example.com ieHcqHmoun.example
I.example.com AuaQuFynAX.example.com BkPSUAlmlf.example.com oGDuvraUwq.example.com ikeyWIZdTs.example.com EvjXkiFEwK.example.com OqDEhENPRm.example.com
mple.com UCjekkUtrF.example.com asElgFuAYB.example.com mXVqZuQHLU.example.com Zxfaacowgg.example.com oBjyUdUYzf.example.com tlkQCrDtrY.example.com EbPUO
com Vt sq.exam .co lgGAfAZ amp lqvpkeu.exa GZZzJFN mple.com SGcWkd.e e.com JF ysoe. le.com QVrIUNP
dKIVuG mple.c hTNlC I.ex le.co examp R.examp JNGFURA examp uVrXx mM.examp
IiEe.e om vC AuToU. om aJD KCB.ex e.co toeFDdRX mple twBRT mple.co uVjj.e le.co dTVv ample.co
example m YEoD .example ouHdopC xample. kbk eoF.exam com Wl DW. m com Jo BFG xample n mOb fA xam .com iQ
le.com SCg e.e ple.com ohlI.ex e.com L wdk example.c YCqo Ju amp .co nfJla .exa e.com dENT2 exa .c fpzWLkx
m pojIl yu.e l om OPL m xample TeeLg x.ex e.com zJ HBnw amp c YG zjoz gFwJ UK.ex le.c N bMSh.e
SSNPfh ample tNbYT .exa .com Ztnt ample. VLdDP .exam .co PmY exam .com JZdf ample m SkfL .example
Kf.exa .com J toJ ple.co OXK e.com pS ple.c nGVO M.e le. mwGErstc xam .com nezpsXh ple.com
ample.com ykvXCknHtw.example.com ldfCsrkCKW.example.com bxOAYrAGtp.example.com ROsumnotHx.example.com xzwAOPoKDv.example.com AdqySwuwfL.example.com sFug
.com YEfNTvIoPi.example.com GXxJWreMLW.example.com uEohxTxopL.example.com MTTTfBnXSt.example.com NaLLpnPxPa.example.com sBBZGnODOD.example.com YUIVWvHOi
mOnKYcicfj.example.com BZwgfwSFtw.example.com ylddgAjlvM.example.com GmaVqGFHim.example.com anYrxYNsQN.example.com gfZmhOFLRP.example.com KtXXiCtafd.exa
OogUd.example.com nPgSBxsVQJ.example.com JMntwjrCAd.example.com klXlCxeqSu.example.com dFuzzgVdWl.example.com fvlUePwqOz.example.com lotzPhDKWG.example.
.example.com eybHmrPmkf.example.com SHNoLoIhxT.example.com claGRNYcOm.example.com jxZnSOJtgg.example.com PnUWAfKzWS.example.com WmWNqxRmKe.example.com J
ple.com zkbkVAMTRu.example.com IDLhvUGFxb.example.com FeCaLskJdj.example.com vOvZRQTvjA.example.com dEQSFxanzt.example.com cKZEHMyRtd.example.com FWYJfy
om ukYXGgoIwi.example.com FOpMqDigdQ.example.com mFLvsMlIgh.example.com LVffWwDAsj.example.com wOONAvFQUG.example.com KuftxrQuau.example.com DVCrfDisnK.
pEsiOaMa.example.com IknDuudBpm.example.com upzNbjCiXA.example.com plfarZcetR.example.com IBTWBLgMRp.example.com gcDCclypTS.example.com nECAlaibzv.exampl
ELz.example.com unrMNBNGTA.example.com uvVOdZwPmZ.example.com GIRvkyNiGW.example.com UGWYmHIHuz.example.com FtDKAwbiZi.example.com VTtVaxvhql.example.com

The NXDOMAIN Storm

Identifying Misconfigurations vs DGA





Identifying Misconfigurations vs DGA (Domain Generation Algorithms)

- **Malware C2**: Thousands of random domains used to find a command server.
- **The Signature**: Massive NXDOMAIN bursts for high-entropy gibberish names.
- **Static Bypass**: Designed to defeated fixed IP/Domain blacklists.

The Baseline Test

- **Typo vs Algorithm**: Comparing simple typing errors (`google.com`) to machine randomness.
- **Entropy Analysis**: Measuring string randomness to flag algorithmic patterns.

Advanced Detection

- **Beaconing**: Queries occurring at fixed, heartbeat-like intervals.
- **Time-Series Spikes**: Sudden volume increases from a single internal host.
- **Resource Strain**: Large storms can overwhelm local resolver caches.

Subdomain Enumeration

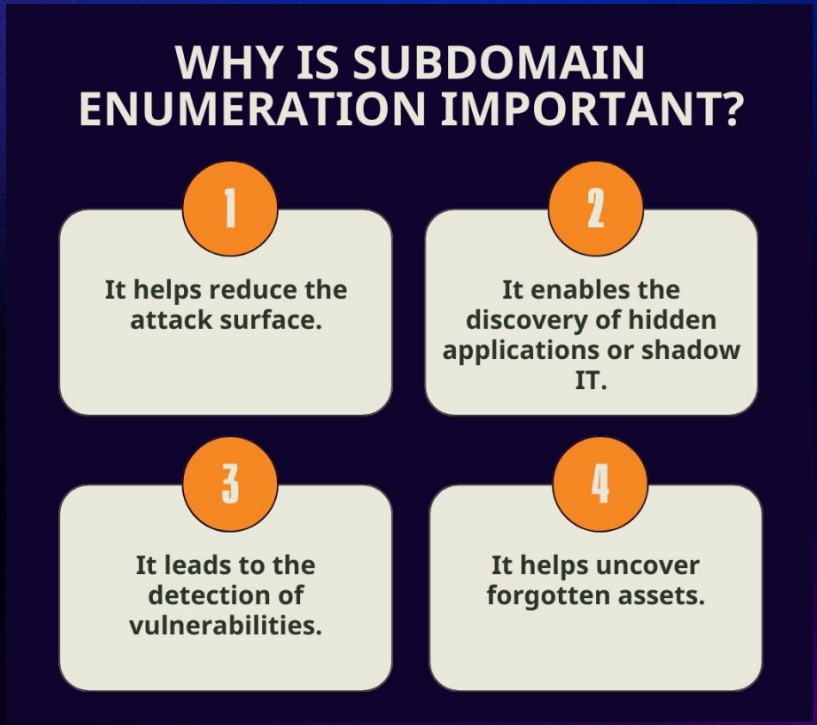
Detecting Active Information Gathering

The Subdomain Sweeps

- **The Guessing Game**: Testing common prefixed like `dev`, `vpn`, `api`, or `test`.
- **The Signature**: A single source IP querying hundreds of unique names in seconds.
- **Mixed Results**: A flood of NXDOMAIN responses punctuated by a few NOERROR hits.

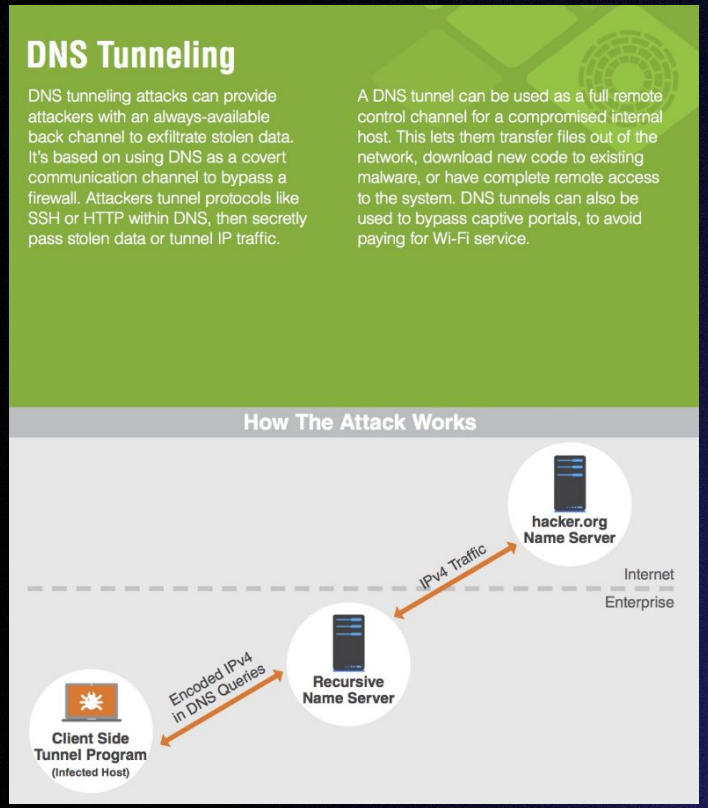
Strategic Impact

- **Target Mapping**: Attackers building a blueprint of your internal infrastructure.
- **Shadow IT**: Discovery of forgotten, unpatched, or unknown staging servers.
- **Subdomain Takeover**: Identifying dangling records that point to expired cloud resources.



Spotting Anomalous Requests

Record Type Analysis



High Risk Record Types

- `TXT/NULL`: Rare in browsing; primary carrier for C2 and Tunneling.
- `MX` **(Mail)**: Suspicious if originating from a standard workstation.
- `SRV` **(Service)**: Often indicaties Active Directory (AD) reconnaissance.

The Why (Risks)

- **Data Payloads**: These records carry arbitrary, encoded data (Base64)
- **Stealth Exfiltration**: DNS is rarely blocked, making it a hidden exit.
- **Network Mapping**: Used to blueprint internal service locations.

The Tunneling Concept

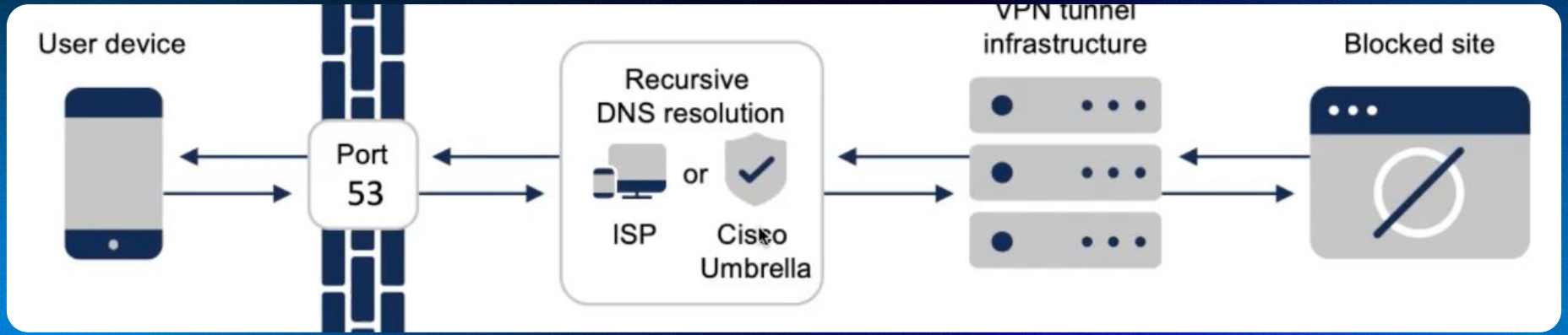
DNS as a Data Transport Layer

Encapsulation Strategy

- **Hiding in Plain Sight**: DNS used as a transport layer.
- **Subdomain Encoding**: Data stashed in the `<ENCODED_DATA>.attacker.com`.
- **Payload Assembly**: Fragmented data reconstructed at the destination.

Bypassing the Perimeter

- **The Firewall Hole**: UDP Port 53 typically remains open.
- **Lack of Inspection**: DNS content is rarely analyzed for binary data.
- **Recursive Routing**: Leveraging internal resolver to proxy stolen data.



Identifying the C2 Heartbeat

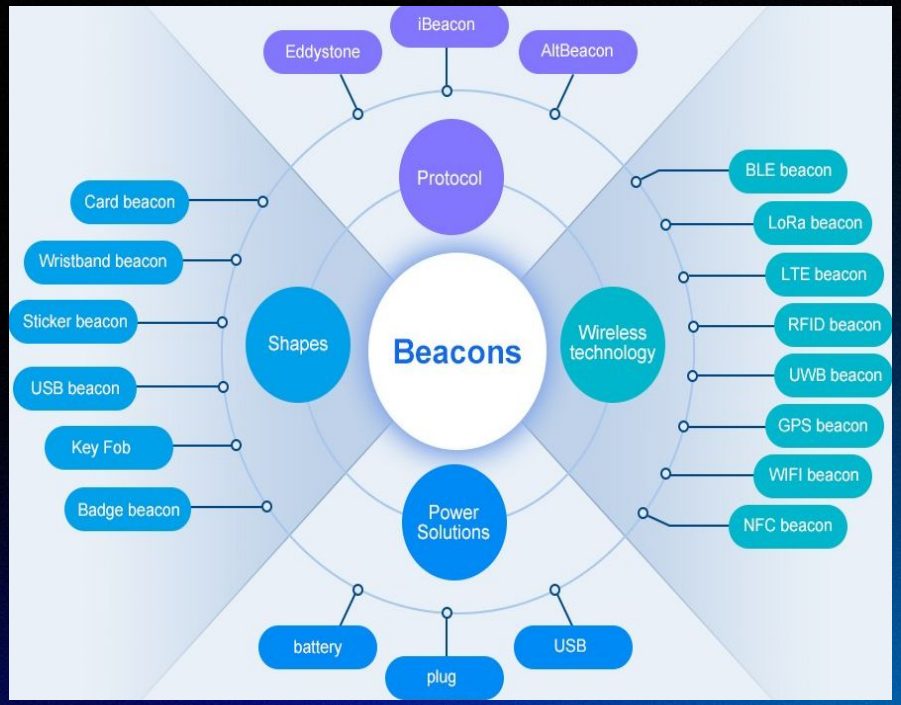
Subdomain Beaconing

The Persistent Check-in

- **Command & Control**: Malware reaching out at regular intervals for instructions.
- **The Heartbeat**: Periodic, automated queries that never stop.
- **State Maintenance**: Keeping the connection alive without constant user activity.

Detection Markers

- **High Query Frequency**: Large volumes of unique subdomains for one parent domain.
- **Low-and-Slow Tactics**: Queries spaced out over hours to bypass volume effects.
- **Time-Series Entropy**: Mathematically consistent timing that lacks human jitter.



The Fingerprints of Encoded Data

Length & Entropy

Character Analysis

- **Abnormal Length**: Queries pushing the 253-character limit to maximize the data transfer.
- **Deep Subdomaining**: Multiple long labels (such as `part1.a9f2.b3c4.c2server.net`) to bypass per-label limits.
- **Non-Human Strings**: Replacing readable names with raw Base64 or Hexadecimal strings.

High Entropy Detection

- **Mathematical Randomness**: Using frequency analysis to score the uniqueness of characters.
- **Visual Discrepancy**: Comparing predictable names (google.com) against high-entropy payloads.
- **Automated Scoring**: Alerting on strings that lack the vowel/consonant patterns of natural language.

The TXT Record Vessel

Smuggling Commands in DNS Responses

Inbound Instruction Delivery

The Dead Drop

Attackers host encoded commands in their domain's TXT records.

The Victim Query

Malware requests the record to check-in for its next task.

Instruction Payload

The DNS response contains the actual command (such as `whoami`, `upload`, or `sleep`).

Identifying Malicious Artifacts

Abnormal Response Size

Large TXT payloads (often >200 bytes) exceeding standard verification strings.

Encoded Scripts

Base64 or Hex strings that decode into PowerShell, Bash, or Python commands.

Recursive Discovery

Using the company's own trusted DNS resolver to pull in the poisoned record.

Volumetric DNS Spikes

Recognizing the Active Leak

The Firehose Effect

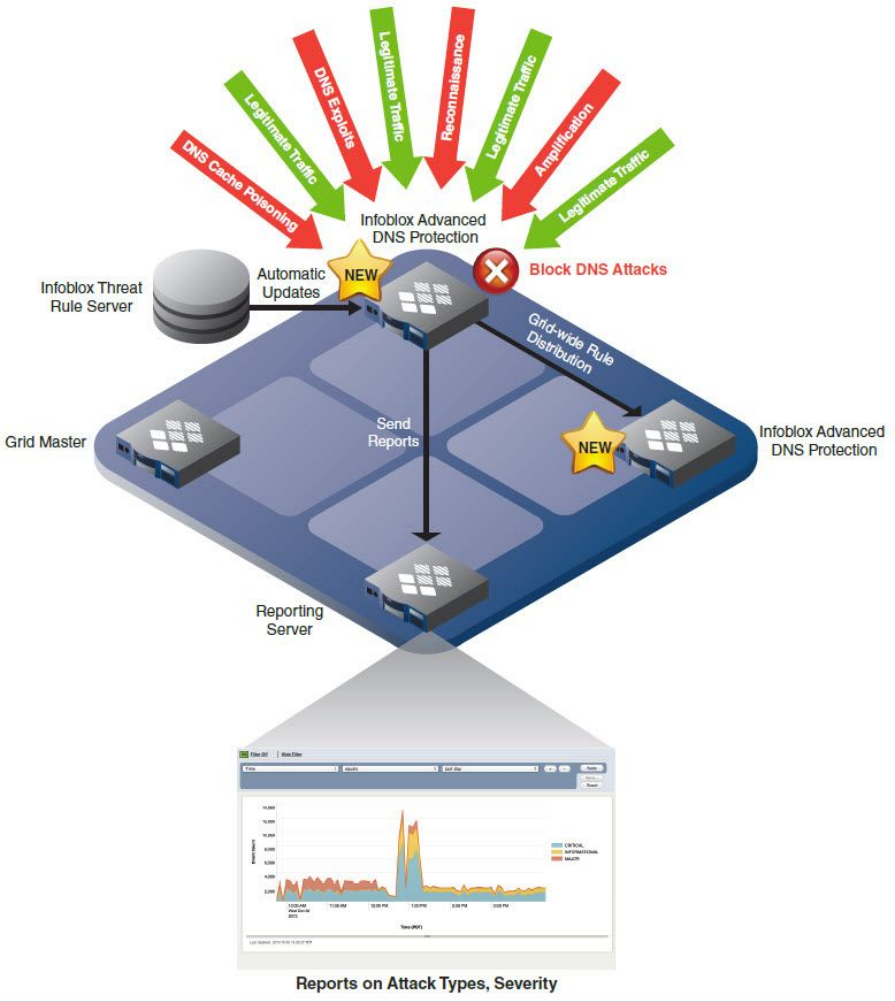
- **Fragmentation**: Large files must be chopped into thousands of tiny DNS queries.
- **Overhead**: Moving a 1MB file can generate over 10,000 unique DNS requests.
- **Persistent Flow**: Continuous, high-speed outbound traffic that doesn't follow normal browsing pauses.

Graphing the Attack

- **The Vertical Spike**: Sudden, massive surges in outbound DNS from a single internal host.
- **Unusual Destinations**: High-volume traffic directed at a single, previously unknown authoritative nameserver.
- **Off-Hours Activity**: Volumetric bursts occurring at 3:00AM or during quiet network periods.

The Statistical Tell

- **Disproportionate Ratio**: Massive DNS query volume with zero corresponding HTTPS/web traffic.
- **Packet Size Asymmetry**: Outbound queries (requests) consistently larger than the inbound response.
- **Unique Subdomain Count**: A 1,000% increase in the number of unique subdomains queried per minute.



Evasion via Rapid Infrastructure Shifting

Time-to-Live (TTL) Manipulation

The Technical Setting

- **Short-Lived Records**: TTLs set to 0 or 60 seconds to bypass local cache.
- **Cache Eviction**: Forcing the client to re-query the authoritative server for every request.
- **Infrastructure Agility**: Allowing the attacker to swap C2 IP addresses in real-time.

The Tactical Purpose

- **Fast Flux DNS**: Rapidly rotating through a pool of compromised IP addresses.
- **Evading IP Blocking**: Making static firewall Deny lists obsolete within minutes.
- **Direct Command Path**: Ensuring the malware always talks directly to the attacker's current active node.

Wireshark Filters for DNS

Surgical Precision in Packet Analysis

Traffic Direction

- `dns.flags.response == 0`: Isolates outbound queries to see what internal hosts are asking.
- `dns.flags.response == 1`: Isolates inbound answers to inspect TXT payloads or server IPs.

String Length Analysis

- `dns.qry.name.len > 20`: Filters for unusually long subdomains typical of data exfiltration.
- `dns.txt > 100`: Targets large TXT records that likely contain encoded commands.

Structural Complexity

- `dns.count.labels > 4`: Identifies deeply nested subdomains (a.b.c.d.e.target.com).
- `dns.qry.type == 16` : Displays only TXT records to quickly spot vessel activity.

Moving from a Suspicious Domain to Threat Intel

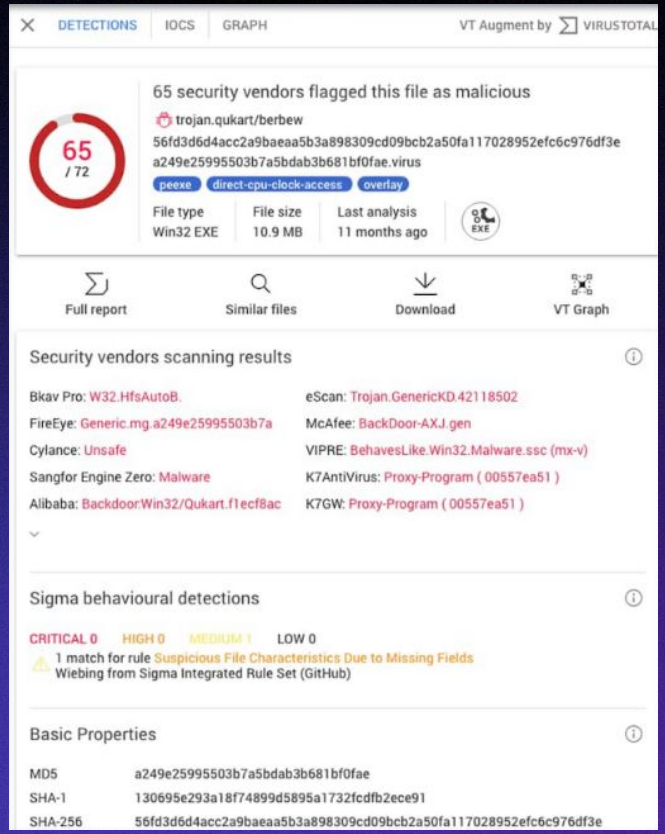
The Analyst’s Pivot

External Validation

- **WHOIS Reputation**: Checking domain age; newly registered domains (NRDs) are high-risk.
- **Passive DNS**: Reviewing historical IP mappings to see if the domain shifts frequently.
- **Threat Intelligence**: Searching VirusTotal or AlientVaunt for known malware associations.

Internal Context

- **Source Attribution**: Identifying which specific internal host initiated the first query.
- **User Behavior**: Determining if the host’s business role justifies a connection to the domain.
- **Timeline Analysis**: Correlation of the DNS query with other suspicious local file or process activity.



Mapping to MITRE ATT&CK

Aligning Evidence to Defensive Frameworks

Command and Control (TA0011)

- **Protocol Abuse (T1071.004)**: Using DNS as a covert communication channel for instructions.
- **Bi-Directional Flow**: Utilizing TXT and CNAME records to push commands into the network.
- **Infrastructure Agility**: Leveraging Fast Flux and short TTLs to maintain a resilient C2 presence.

Exfiltration (TA0010)

- **Exfiltration over C2 Channel (T1041)**: Stealing data through the same DNS tunnel used for commands.
- **Protocol Impersonation**: Hiding sensitive data strings within standard-looking outbound queries.
- **Stealth Fragmentation**: Breaking large files into thousands of small, low-risk DNS packets.

Reconnaissance (TA0043)

- **Network Information Gathering (T1590)**: Using DNS to map internal active directories and hostnames.
- **Active Scanning**: Forcing internal resolver to reveal path information to external authoritative servers.
- **Victim Profiling**: Identifying security stack versions through DNS response behavior.

Conclusion | Hardening the DNS Perimeter

Key Takeaways

- **The Visibility Paradox**: DNS is the phonebook of the internet, but it's high volume and ubiquity makes it a perfect hiding place for threat actors. Port 53 must be monitoring.
- **Patterns Over Packets**: Individual queries may look benign, but security value is found in behavioral patterns:
- **High Entropy: Random strings (DGA)**
- **Volumetric spikes**: Large data transfers (Exfiltration)
- **Frequency/Jitter**: Consistent check-ins (C2 Heartbeats)
- **The Vessel Risk**: Non-standard use of TXT, NULL, and SRV records are primary indicators of covert tunneling and instruction delivery.

Strategic Defensive Actions

- **Detection:** Implementing Entropy Scoring and NXDOMAIN Threshold alerts to catch DGAs and scanning.
- **Analysis:** Use specialized Wireshark filters (`dns.qry.name.len > 20`) to isolate suspicious payloads.
- **Prevention:** Deploy DNS filtering (DNSFW) to block Newly Registered Domains (NRDs) and known malicious TLDs.
- **Architecture:** Enforce Strict Recursion; only allow internal resolvers to talk to the internet, blocking direct outbound DNS from workstations.